

Security+ 4.5 · Web Filtering

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.5 — Web Filtering (10:00)** ·

[Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Web filtering: URL scanning por categoria; content filter; proxy HTTP (intermédia); DNS blocklist (bloqueia na resolução); reputation; bot detection.

Highlights que a prova cobra

- DNS blocklist: bloqueia ANTES do browser abrir o site
- Web proxy: intermédia o HTTP/S e pode inspecionar

Dicas de prova & Cenários Típicos

- 'blocks domains at the DNS level'=DNS filtering

Cenário clássico de exame: 'empresa bloqueia acesso a sites de phishing via DNS'=DNS filtering.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.5 — Web Filtering)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Atacante testa senhas VAZADAS de um site em VÁRIOS outros sites (reúso de senha):

- A)** Credential stuffing
- B)** Força bruta pura
- C)** Rainbow table
- D)** Vishing

2. Um atacante usa RFID para clonar crachás de funcionários e acessar áreas restritas. Que tipo de ataque físico é esse?

- A) Tailgating**
- B) Shoulder surfing**
- C) Clonagem de credenciais**
- D) Dumpster diving**

3. Cenário corporativo (Web Filtering): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'DNS blacklist: bloqueia ANTES do browser abrir o site'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Implementar a solução correspondente: DNS blacklist: bloqueia ANTES do browser abrir o site...**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

4. Cenário corporativo (Web Filtering): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'Web proxy: intermédia o HTTP/S e pode inspecionar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Implementar a solução correspondente: Web proxy: intermédia o HTTP/S e pode inspecionar...**
- C) Substituir controles técnicos preventivos por termos de adesão informais**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

5. Cenário corporativo (Web Filtering): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: '"blocks domains at the DNS level'=DNS filtering'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Implementar a solução correspondente: 'blocks domains at the DNS level'=DNS filtering...**
- C) Substituir controles técnicos preventivos por termos de adesão informais**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

6. Cenário corporativo (Web Filtering): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'empresa bloqueia acesso a sites de phishing via DNS'=DNS filtering.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa bloqueia acesso a sites de phishing via DNS'=DNS filtering....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Web Filtering): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'DNS blocklist: bloqueia ANTES do browser abrir o site'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DNS blocklist: bloqueia ANTES do browser abrir o site...

8. Cenário corporativo (Web Filtering): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'Web proxy: intermédia o HTTP/S e pode inspecionar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Web proxy: intermédia o HTTP/S e pode inspecionar...

9. Cenário corporativo (Web Filtering): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: "blocks domains at the DNS level"=DNS filtering'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'blocks domains at the DNS level'=DNS filtering...

10. Cenário corporativo (Web Filtering): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: "empresa bloqueia acesso a sites de phishing via DNS"=DNS filtering.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'empresa bloqueia acesso a sites de phishing via DNS'=DNS filtering....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Credential stuffing.

✓ **Por que está certa:** Credential stuffing é um ataque cibernético no qual o atacante utiliza listas de credenciais (pares de usuário e senha) obtidas de violações de dados em um site para tentar autenticar em vários outros sites, explorando a prática comum de reúso de senhas. O ataque é automatizado e depende de grandes volumes de credenciais vazadas. Diferencia-se da força bruta pura porque não tenta adivinhar senhas, mas usa combinações já conhecidas. É um tópico do domínio de Ameaças, Vulnerabilidades e Mitigação da Security+ (SY0-701), objetivo 2.4, que aborda técnicas de ataque.

✗ **Por que as outras estão erradas:**

- *Força bruta pura:* Força bruta pura é um método de ataque que tenta exaustivamente todas as combinações possíveis de caracteres até encontrar a senha correta. No credential stuffing, o atacante não testa combinações aleatórias; ele usa credenciais previamente vazadas e válidas em outro contexto. A força bruta é computacionalmente intensiva e facilmente detectável por bloqueios de conta, enquanto o credential stuffing explora a reutilização de senhas e pode ser mais furtivo, pois as credenciais são legítimas. Portanto, a força bruta pura não descreve o cenário de teste de senhas vazadas em vários sites.
- *Rainbow table:* Rainbow table é uma técnica de quebra de hash que utiliza tabelas pré-computadas de hashes de senhas para reverter funções de hash criptográficas. Ela é usada quando o atacante obtém hashes de senhas e deseja descobrir as senhas em texto claro. No entanto, o enunciado descreve o uso de senhas já vazadas (em texto claro ou já quebradas) para autenticar em outros sites, não a quebra de hashes. Rainbow tables não se aplicam diretamente ao credential stuffing, que não requer quebra de criptografia, mas sim a exploração de reúso de credenciais.
- *Vishing:* Vishing é uma forma de engenharia social que utiliza chamadas telefônicas ou mensagens de voz para enganar vítimas e obter informações confidenciais, como senhas ou dados financeiros. Não envolve o teste automatizado de credenciais vazadas em múltiplos sites. O cenário descrito é claramente um ataque técnico de automação, não uma interação humana de persuasão. Portanto, vishing não se aplica ao contexto de credential stuffing, que é um ataque em massa baseado em listas de credenciais.

2) C — Clonagem de credenciais.

✓ **Por que está certa:** A alternativa correta é 'Clonagem de credenciais'. A clonagem de credenciais ocorre quando um atacante copia os dados de um cartão de acesso (como crachás RFID ou cartões de proximidade) para outro dispositivo, permitindo acesso não autorizado. No cenário, o uso de RFID para copiar o sinal do crachá e replicá-lo em um cartão virgem é um exemplo clássico de clonagem de credenciais físicas. A CompTIA Security+ aborda ataques físicos e contramedidas, como o uso de cartões com criptografia ou autenticação mútua para prevenir clonagem.

✗ **Por que as outras estão erradas:**

- *Tailgating:* Tailgating é a prática de seguir fisicamente uma pessoa autorizada através de uma porta segura sem usar credenciais próprias. Não envolve clonagem de cartões ou RFID; é uma intrusão física passiva. A alternativa é incorreta porque o enunciado descreve a cópia eletrônica de credenciais, não a entrada por proximidade.
- *Shoulder surfing:* Shoulder surfing é a observação direta por cima do ombro para obter informações como senhas ou PINs. Não envolve RFID ou clonagem de crachás. A alternativa é incorreta porque é uma técnica de observação visual, não de duplicação eletrônica.
- *Dumpster diving:* Dumpster diving é a busca em lixeiras por informações descartadas

(documentos, mídias) que possam ser úteis ao atacante. Não tem relação com RFID ou clonagem de credenciais. A alternativa é incorreta porque se trata de recuperação de dados descartados, não de interceptação e cópia de sinais de cartão.

3) C — Implementar a solução correspondente: DNS blocklist: bloqueia ANTES do browser abrir o site....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Web Filtering): DNS blocklist: bloqueia ANTES do browser abrir o site.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Web proxy: intermédia o HTTP/S e pode inspecionar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Web Filtering): Web proxy: intermédia o HTTP/S e pode inspecionar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'blocks domains at the DNS level'=DNS filtering....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Web Filtering): 'blocks domains at the DNS level'=DNS filtering.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'empresa bloqueia acesso a sites de phishing via DNS'=DNS filtering.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Web Filtering): 'empresa bloqueia acesso a sites de phishing via DNS'=DNS filtering..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: DNS blacklist: bloqueia ANTES do browser abrir o site....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Web Filtering): DNS blacklist: bloqueia ANTES do browser abrir o site.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: Web proxy: intermédia o HTTP/S e pode inspecionar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Web Filtering): Web proxy: intermédia o HTTP/S e pode inspecionar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'blocks domains at the DNS level'=DNS filtering....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Web Filtering): 'blocks domains at the DNS level'=DNS filtering.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: 'empresa bloqueia acesso a sites de phishing via DNS'=DNS filtering.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Web Filtering): 'empresa bloqueia acesso a sites de phishing via DNS'=DNS filtering..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.